

Development session report

18-19 August 2026 — what existed, what changed, why, and what it means in practice.

| How to read this

Every item below follows the same shape: **what existed, what changed, why, and what it means in practice**. The "why" matters more than the "what" — several of these were found while looking for something else, and the reasoning is what stops them coming back.

Headline: **12 defects fixed, 2 features built, 1 packaging pipeline replaced**. The automated suite went from **178 tests to 221**. Three of the fixes were things that could take a customer's system down; one was a security hole that could run script in an administrator's browser.

| 1 · The reported bug: agents stuck on "punch in at the door"

What existed

An organisation was switched from *With biometric device* to *Without biometric device* because it had finished testing with the readers. The setting saved. But every employee's agent still showed "**Punch in at the door to start**" and refused to begin a work session. Exiting the app, unbinding and re-binding the device, and hard-refreshing the console all made no difference.

What was wrong

`GateService::enabledFor()` — the single function that decides "is this company gated?" — never read `attendance_mode` at all. It looked at two other switches and at whether any biometric device row still existed. Switching to *Without biometric device* deletes no device rows, so as far as the gate was concerned nothing had changed.

Worse, that switch also hides the Biometric screen from the menu — and the Gate-to-PC toggle lives on that screen. So there was no longer any way in the console to turn the gate off. A genuine dead end.

Why the fix is shaped this way

Without biometric device is now checked **first** and out-ranks everything else — leftover device rows, the `gate_enabled` flag, even an explicit `biometric_gate = 'on'`. The reasoning is simple: there is no door, so there can be no gate. Any other precedence leaves room for the same class of bug.

Impact

Agents release themselves **within about 15 seconds** — the agent re-polls continuously, so nobody reinstalls, re-binds or logs out. Two regression tests now hold the behaviour in place.

| 2 · New feature: the Gate-to-PC Exclusion Policy

What existed

Gate-to-PC was all-or-nothing per company. The only escape was a one-shot emergency override that faked an IN punch and expired the same day — so an administrator was re-approving the same people every single morning.

Why it was needed

Four real situations, all of which end with a productive employee at a locked PC:

1. **The reader is down** — nobody at that site can punch in.
2. **One person's punch is rejected** — a cut finger, a worn enrolment, a damaged card.
3. **The punch happens but never arrives** — the site's network or internet link is down, so the punch sits on the device. This is the most common and least obvious case: nothing is broken at the door and nothing is broken with the employee; the server simply cannot see an arrival that genuinely happened.
4. **People who never pass a reader** — night shift, field engineers, work-from-home, contractors.

What was built

A nullable, tri-state setting on **five levels** — Machine, Employee, Team, Department, Branch — resolved most-specific-first. Each level is *Inherit* (default), *Excluded* or *Required*. **Required** is what makes it usable at scale: exclude a whole branch while its reader is being repaired, but keep the security team behind the gate.

Every exclusion carries **valid-from / valid-until dates**, a **reason**, and the **admin who granted it**. Blank dates mean permanent.

The design decision that matters most

Dated exclusions **expire by themselves**. A temporary exclusion that must be manually removed *will not be removed* — someone grants it on a Tuesday because the reader is broken, the engineer comes Thursday, and it is still there a year later, at which point the control has quietly stopped existing and nobody knows. There is no scheduled job to fail and no reminder to ignore: outside its window the setting simply reads as unset.

Dates are evaluated in the **customer's own timezone**, not UTC.

Impact

A new **Manage → Gate Exclusions** screen lists every exception in the company with Active / Scheduled / Expired status, the reason, and who granted it — so a temporary exception can no

longer become permanent unnoticed. Nothing is excluded until an administrator creates an exclusion, so applying this changes no existing behaviour. **27 tests.**

| 3 · Twelve defects found by reviewing our own work

The change above was put through two adversarial review rounds, deliberately hunting for ways the gate could be wrongly lifted. Both rounds found real bugs. These were all fixed before release.

#	What it was	Why it mattered
1	Cross-tenant device carry-over. A laptop re-registered by a second client kept the first client's exclusion. <code>device_uuid</code> is agent-supplied, so reachable on purpose as well as by accident.	One client's admin could lift another client's gate.
2	XSS in the new table. <code>esc()</code> encodes <code>'</code> as <code>&#39;</code> ; the HTML parser decodes it <i>before</i> compiling an inline <code>onclick</code> , so the string re-opens. A crafted branch name — or a <code>computer_name</code> , which the agent supplies freely — could run script in an admin's session.	Also broke the Remove button for any name containing an apostrophe.
3	Dates evaluated in UTC. An exclusion "until the 22nd" kept lifting the gate through 05:30 on the 23rd in Asia/Kolkata.	Exactly the night shift the feature was written for.
4	Soft-deleted branches kept granting exclusions. <code>withoutGlobalScopes()</code> also strips the soft-delete scope.	Deleting a branch to re-gate its staff silently did nothing.
5	Screenshot ingestion resolved the gate at a different level from every other route.	Blocked an excluded machine forever and admitted a <code>REQUIRED</code> one.
6	A device-less gate poll reported the wall down for a machine marked <code>REQUIRED</code> .	The agent started, then hit an unexplained 423.
7	An unbound machine still walled its former user.	No visible cause anywhere in the console.
8	A window-only edit turned a dated exclusion permanent and kept the previous admin's name on it.	Extending someone else's exclusion made <i>them</i> accountable for your decision.
9	<code>gate-trace</code> 403'd every <code>SUPER_ADMIN</code> (their <code>company_id</code> is null).	The same bug already exists in <code>policyTrace</code> — worth a look.
10	<code>excluded_level</code> named a level that had said Required .	Support would read it as the opposite of the truth.
11-12	Two payload-shape and precedence issues caught in the first round.	—

Why this is in the report

None of these were found by testing the happy path. They were found by a reviewer told to *attack* the change. On a security control that is the only review worth doing — and it is worth repeating for the remaining hardening work.

| 4 · On-premise packaging: what was going out to clients

What existed

`deployment/rebuild-server-zip.bat` built the client ZIP. Two problems.

It was broken. `deployment/build-log.txt` records `"failed. was unexpected at this time."` — a delayed-expansion bug around the `robocopy` errorlevel check.

When it did run, it shipped things it should not have:

- `docs/` — including **the sales deck (pptx and pdf)**, two bugfix reports, the QA delivery report, the technical & business-logic write-up, and the QA test cases;
- `tests/` and the dev batch files;
- `storage/app/backups` — **our own database backups**;
- `storage/app/smartept` — **another company's stored screenshots**;
- the build script itself, revealing the Central path.

On a perpetual on-premise licence, all of that sits on the client's server permanently.

What replaced it

`deployment/make-clientside.php` — plain PHP, so the same command runs on Windows and Linux, and no batch file is involved.

```
php deployment/make-clientside.php C:\laragon\www\smartept-clientside --sync
```

It produces the pure application and nothing else, and **refuses to run** when `vendor/` contains `phpunit`, `mockery` or `fakerphp`. That guard has already earned itself once in real use.

`--sync` is the update path: it re-copies, then **prunes** anything under the directories it owns that has gone from the product, while never touching `.git`, `.env`, `license.lic`, `storage/` or `vendor/`. So the client repo stays a true mirror and its `git status` shows exactly what a release changed.

Impact

`C:\laragon\www\smartept-clientside` now holds **7,630 files / 37.8 MB** — the complete application including vendor, verified to boot. Refreshing it after any product change is one command.

| 5 · Two licence defects that were hurting paying customers

5.1 A paid offline client could be bricked by a *successful* phone-home

What existed. Uploading a `.lic` sets `license_key`, so the install counted as configured and called `smartept.com` daily. If Central did not recognise that key — which is exactly what happens when a licence was issued offline as a file — `LicenseClient` **overwrote the good `.lic` verdict with `unknown_key`** and blocked the entire console. It also cost a ~10-second synchronous timeout once a day on a server that has no internet by design.

Why the fix is shaped this way. A file licence is verified locally against our public key and the machine's fingerprint. That signature *is* the proof — Central adds nothing to it and must never be able to overrule it. Central not recognising a key means Central is out of date, not that the client is unlicensed. So a file licence no longer phones home at all, and even an explicit **Revalidate** click can no longer demote it.

Impact. A perpetual offline client cannot be taken down by our own infrastructure, and the daily page hang is gone. This also restores the "no internet ever needed" promise our own install guide makes.

5.2 Any random key granted permanent access offline

What existed. Status `unconfigured` — "a key was saved but Central has never confirmed it" — counted as operational **forever**. On an air-gapped server, typing any string into the Licence screen granted permanent, uncapped access, and the seat cap lifted too.

Why the fix is shaped this way. `unconfigured` is a genuine transient cloud state, so it is still allowed — but only for the same 7 days the no-key evaluation gets, measured **from when the key was saved**, not from `created_at`. Measuring from `created_at` would have instantly blocked long-established cloud tenants hitting a transient state: the fix would have caused a worse outage than the bug.

Impact. A random key now buys a week, not forever. Genuine `.lic` clients are unaffected — a signed file sets the status to `active`, never `unconfigured`. A test proves a perpetual licence still works 400 days later.

| 6 · Developer licence toggle

What existed. Turning enforcement off for local testing meant editing `.env` — the same switch a client could edit.

What was built. `php artisan smartept:licence off | on | status`.

Why it is keyed, not a marker. A bare file that disabled licensing would be the easiest bypass we could ship; any client would find it within a week. The file holds `HMAC-SHA256(secret, 'SMARTEPT-DEV-OFF|' + machine fingerprint)`, so it works only on the machine that wrote it, and forging one needs the secret inside the encoded `app/`. It fails safe on every error path, is gitignored, and is excluded from the client build so it cannot leak by accident.

Impact. A supported way to test locally that will survive the licence hardening still to come — and one switch (`DevLicenceKey::enforcementOn()`) now drives all three enforcement points, which previously each read config separately.

7 · Incidental findings

XLSX export was dead in production. `phpoffice/phpspreadsheet` was added to `composer.json` by hand in the `17-08-2026 update1` commit and never installed, so it was missing from `composer.lock` and from `vendor/`. `ProductivityController` guards with `class_exists` and returns **503 "Excel export needs the PhpSpreadsheet library"**. Anyone clicking XLSX export got an error. Resolved and locked.

SMARTEPT_ONPREM was missing from `.env.example`. Without it `/activate` renders the "managed by Ametecs" notice and `POST /activate` returns 404 — **an on-premise client could not activate at all.** Now documented.

14 security advisories across 3 packages, reported by Composer and not yet audited. This matters more than usual: a perpetual on-premise client keeps whatever ships, unpatched, for years.

8 · What is still open

Item	Why it matters
Licence hardening B3-B6	Encoding <code>app/</code> protects the <i>source</i> , not the <i>licence</i> . Seven bypasses still live outside <code>app/</code> — one line in <code>.env</code> , one word in <code>routes/api.php</code> , one SQL statement, or copying <code>storage/app/.machine_fp</code> to defeat node-locking. Today's fixes addressed the two that hurt honest customers; these are the ones that stop a dishonest one.
<code>composer audit</code>	The 14 advisories above.
XSS sweep of <code>admin.blade.php</code>	Defect #2 was fixed in the new table; other tables are built the same way with inline <code>onclick</code> .
SourceGuardian targets	The encoder's version and its loader files decide whether PHP 8.2 and 8.3 are both supported. Note the build machine carries four PHP 8.5 builds — loaders for 8.5 lag well behind release.
QA execution	The manual test pack is written and ready to hand over.

| 9 · By the numbers

	Before	After
Automated tests	178	221
Failing tests	3	1 (pre-existing, unrelated: <code>QaPhase4 meeting_mode</code>)
Client ZIP contents	sales deck, QA reports, our DB backups, another company's screenshots	pure application only
Client build	broken script	one command, 7,630 files, verified to boot
Ways to grant a standing gate exception	none	5 levels, dated, audited

Ametecs India — internal. SmartEPT · Employee Productivity Tracking.